Claude Code sandbox: structure and access rules

`~/.claude` @ `6a1da04` + uncommitted fixes

2026-10-29

Goal. Claude works freely in the current repo. Anything else in `~` needs your approval. Secrets and the sockets that could escape the sandbox stay unreachable, whatever you approve. Two threats are covered: Claude's mistakes and hostile code that Claude runs.

Legend.

BLOCKED no approval opens it (only a manual settings edit) PROMPT you approve it each time FREE no prompt.

1 Layers and how they connect

Each tool call passes through the layers that apply to it. A call is allowed only if every layer allows it.

Layer	Applies to	What it does
1. Permission rules	all tools	`deny` > `ask` > `allow`. Secrets are denied for Read and Edit; toolchain reads are allowed; `ask` on `EnterWorktree`, `ssh`, `scp`, unsandboxed Bash.
2. PreToolUse hooks	Bash, Agent, Edit, Write	`git-guard.py`: branches and worktrees prompt. `outside-repo-guard.py`: edits outside the repo, in `.git/` or in Claude's config prompt. `bg-guard.py`: background jobs may not edit existing files.
3. Sandbox (bubblewrap)	Bash only	Own mount, PID and network namespaces. The filesystem is limited to the repo, toolchain dirs and `$TMPDIR`. Rules are re-read live from settings.
4. Network proxy	sandboxed Bash	Only `allowedDomains` pass freely; other hosts prompt (manual mode) or go to the auto-mode classifier.
5. SessionStart hook	each session	`sandbox-bootstrap.sh` adds the repo path to `allowRead` in the repo's `.claude/settings.local.json` and keeps that file out of git.

Key asymmetry. The sandbox wraps *Bash only*. The Read, Edit and Write tools are not sandboxed; for them, layers 1 and 2 are the whole defence. That is why secrets have both a sandbox deny and a permission deny, and why `outside-repo-guard.py` exists.

2 BLOCKED Always blocked

Path	Bash (sandbox)	Read/Edit tools
`~/.ssh`, `~/.gnupg`, `~/.local/share/keyrings`, `~/pwd.txt`, `~/.claude/.credentials.json`	denied	denied
Browser and mail: `~/.mozilla`, `~/.thunderbird`, `~/.cache/{mozilla,librewolf,thunderbird,evolution,aerc}`	denied	denied
Escape sockets: `/run/user/1000` (sway, systemd, D-Bus session, ssh agent), `/tmp/.X11-unix`, `/tmp/.ICE-unix`, `/run/dbus/system_bus_socket`, `/tmp/.mathworks-1000`	denied	n/a
Abstract-namespace sockets (X11, session bus)	refused (own net ns)	n/a
Other processes via `/proc/<pid>/root`	own PID ns	n/a

Blocked for Bash only (the file tools prompt instead)

Path	Why
`<repo>/.git/hooks`, `<repo>/.git/config`, `~/.claude/{settings.json,hooks,skills,agents,CLAUDE.md,...}`	read-only mounts (built in): they run code outside the sandbox
`~/.ipython/profile_default/{startup,ipython_config.py/.json,ipython_kernel_config.py/.json}`	`denyWrite`: run at IPython start
`~/.jupyter/jupyter_{server,lab,notebook}_config.{py,json}`, `~/.jupyter/custom`, `~/.local/share/jupyter/{kernels,labextensions,nbextensions}`	`denyWrite`: run at Jupyter or kernel start
`~/.Mathematica/{Kernel,Autoload,Applications,FrontEnd/init.m,Paclets/Repository}`	`denyWrite`: run at kernel or front-end start
`~/.matlab/R2024a/javaclasspath.txt`	`denyWrite`: loads classes ahead of MATLAB's
Everything else in `~` not listed in Section 4	`denyRead ~/`

3 PROMPT Needs your authorization

Action	Mechanism	Notes
Read tool outside the working dirs and the allow list	Claude Code default	prompts in auto mode too
Edit/Write outside the repo, `/tmp/claude-1000`, memory and plans	`outside-repo-guard.py`	`ask` overrides the auto classifier
Edit/Write in any `.git/` or in Claude's hooks/settings/skills/agents/`CLAUDE.md`	`outside-repo-guard.py`	even inside the repo
Unsandboxed Bash (`dangerouslyDisableSandbox`)	ask rule	runs with your full rights
`ssh`, `scp`	ask rule	fail in the sandbox anyway (no `~/.ssh`)
Create, move or delete a git branch or worktree; `EnterWorktree`; Agent in a worktree	`git-guard.py`, ask rule	
Network host not in `allowedDomains`	proxy	manual mode: you. Auto mode: classifier (accepted)
Edit of a repo's `.claude/settings.local.json`	built-in protection	the permanent grant route

4 FREE Free

Access	Where
Read + write	the current repo (Bash via the bootstrap grant; file tools via the working dir)
Read + write	`$TMPDIR` = `/tmp/claude-1000`; file tools also `~/.claude/projects`, `~/.claude/plans`
Read	`~/.gitconfig`, `~/.config/git`, `~/.condarc`, `~/miniconda3`, `~/.cargo`, `~/.rustup`, `~/.keras`, `~/nltk_data`, `~/Documents/MATLAB`, `~/MATLAB Add-Ons`, `~/.claude`, and the write list below
Read + write	`~/.conda`, `~/.cache` (pip: `claude-pip`, conda: `conda-pkgs`), `~/.astropy`, `~/.config/matplotlib`, `~/.ipython`, `~/.jupyter`, `~/.local/share/jupyter`, `~/.Mathematica`, `~/.Wolfram`, `~/.matlab`, `~/.MathWorks`, `~/.MATLABConnector`, `~/.texlive2023`, `/tmp/MathLink`, `/tmp/MathWorks-1000` (minus Section 2)
Network	PyPI, Anaconda, GitHub, GitLab, Bitbucket, Codeberg, GWOSC, Zenodo, arXiv, INSPIRE, MathWorks
Unix sockets	any reachable path (`allowAllUnixSockets`, needed by MATLAB): leaves snapd, cups, avahi, journal, ...

5 Escalation when Bash is blocked

Claude stops, names the path or host and why it needs it, then offers, in this order:
1. **Session:** you type `/add-dir <path>`. Opens reads and writes until the session ends.
2. **Permanent:** a prompted edit adding the path to `allowRead`/`allowWrite` in the repo's `.claude/settings.local.json`. Takes effect immediately.
3. **Unsandboxed retry:** only for git remote operations over ssh, or as a last resort you agree to. Always prompts.

Claude never works around a block (copying files into the repo, other tools, other paths).

6 Accepted risks

- An approved unsandboxed retry has your full rights: secrets, sockets, and git hooks run unsandboxed. Read the command before approving.
- In auto mode, the classifier, not you, may approve new network hosts.
- Connectable system sockets (snapd, cups, avahi, acpid, journal, uuidd, userdb): no code execution without polkit, which is unreachable.
- `~/.matlab/credentials` is readable: MATLAB's online licensing needs it.
- Package caches (`conda-pkgs`, `claude-pip`) can be poisoned, but only envs that Claude creates use them.

7 Open questions

- Does `/add-dir ~` or an `allowRead` entry beat the specific `~/.ssh` deny? Untested.
- A second `matlab -batch` in the same Bash call hangs at the MathWorks login prompt; one per call works.